

Reporte de Pentest

Práctica 1. Análisis y planificación del pentest

Preparado para: **Aurora Market**

Preparado por: Andrea Sandoval

Fecha: 5 de septiembre del 2026

Clasificación: Confidencial

1. Objetivo del Pentest

- Conocer el nivel de exposición y seguridad de la aplicación web de Aurora Market.
- Identificar posibles vulnerabilidades y evaluar los riesgos asociados, verificar si la situación reportada por un usuario puede corresponder a una vulnerabilidad de seguridad.
- Proporcionar información clara, técnica y útil que permita a Aurora Market tomar decisiones y establecer medidas de mitigación.

2. Alcance

- SÍ SE EVALUARÁ:

Únicamente la aplicación web de Aurora Market que haya sido formalmente autorizada.

Las funcionalidades disponibles dentro de la aplicación, incluyendo:

- Registro e inicio de sesión.
- Gestión de cuentas de usuario.
- Consulta y búsqueda de productos.
- Proceso de compra.
- Consulta del estado de pedidos.
- Área administrativa (únicamente en la medida en que se encuentre dentro del alcance autorizado).

- NO SE EVALUARÁ:

- Redes sociales de Aurora Market.
- Equipos personales de empleados.
- Cuentas de correo electrónico.
- Proveedores o servicios externos.
- Sistemas que no formen parte del alcance autorizado.
- Información real de clientes mediante acciones que puedan alterarla, eliminarla o ponerla en riesgo.

3. Autorización y condiciones

- Permisos requeridos:

Aurora Market proporciona autorización formal al equipo de ethical hacking para realizar una evaluación de seguridad sobre la aplicación web autorizada.

- Condiciones acordadas:
 - Las pruebas se realizarán únicamente sobre los activos incluidos en el alcance.
 - No se realizarán acciones destinadas a interrumpir deliberadamente el funcionamiento de la plataforma.
 - Se evitará modificar, eliminar o comprometer información real de los clientes.
 - Las pruebas se realizarán preferentemente durante horarios de menos actividad para minimizar posibles impactos operativos.
 - Las actividades de evaluación deberán realizarse de manera controlada, documentada y conforme a la autorización proporcionada.
 - Cualquier situación que pueda representar un riesgo significativo para la disponibilidad o integridad de la plataforma deberá comunicarse oportunamente a Aurora Market.
 - La evaluación se desarrolla bajo principios de responsabilidad, transparencia, confidencialidad y comunicación con el equipo responsable.

4. Tipo de pentest

Gray-box:

Se utilizará un enfoque **Gray box**, debido a que Aurora Market proporciona información parcial sobre su entorno.

El equipo conoce inicialmente que existe una aplicación web, una base de datos, mecanismos de autenticación y diferentes tipos de usuarios, pero no dispone de toda la información relacionada con la arquitectura, tecnologías, configuraciones y componentes internos de la plataforma.

Este enfoque permite evaluar la seguridad desde una perspectiva intermedia entre un atacante externo que posee poca información y un usuario con conocimiento interno de la infraestructura.

Además, permite analizar de manera particular los controles de autenticación y autorización de los diferentes tipos de usuarios, especialmente debido al reporte de un posible acceso a información perteneciente a otra persona.

5. Planificación

La evaluación se organizará en diferentes etapas con el objetivo de realizar las pruebas de forma controlada y minimizar el impacto sobre las operaciones de Aurora Market.

5.1 Preparación

- Confirmar la autorización formal para realizar el pentest.
- Definir y documentar el alcance.
- Identificar los activos y funcionalidades autorizadas.
- Establecer horarios de prueba.
- Definir los canales de comunicación con Aurora Market.
- Establecer procedimientos para reportar incidentes o situaciones de riesgo durante la evaluación.

5.2 Identificación de la superficie de ataque

Se realizará un reconocimiento de la aplicación para identificar:

- Páginas y funcionalidades disponibles.
- Formularios y puntos de entrada de información.
- Mecanismos de autenticación.
- Roles y tipos de usuario.
- Parámetros utilizados por la aplicación.
- Posibles interfaces o endpoints accesibles.

5.3 Evaluación de vulnerabilidades

Se analizarán las diferentes funcionalidades de la aplicación para identificar posibles vulnerabilidades relacionadas con:

- Autenticación.
- Autorización y control de acceso.
- Gestión de sesiones.
- Validación de entradas.
- Manejo de información sensible.
- Configuraciones de seguridad.
- Procesos relacionados con usuarios, productos, compras y pedidos.

Se dará especial prioridad a las vulnerabilidades relacionadas con el posible acceso de un usuario a información perteneciente a otra cuenta.

5.4 Explotación controlada

Las vulnerabilidades identificadas serán verificadas mediante pruebas controladas, únicamente hasta el nivel necesario para confirmar su existencia y determinar su impacto.

No se realizarán acciones que puedan provocar indisponibilidad del servicio, alterar información real o afectar a otros usuarios.

5.5 Evaluación del impacto

Cuando una vulnerabilidad sea confirmada, se analizará su posible impacto sobre:

- Confidencialidad de la información.
- Integridad de los datos.
- Disponibilidad de la aplicación.
- Información personal de los clientes.
- Información relacionada con pedidos y compras.
- Reputación de la empresa.

5.5 Documentación

Cada vulnerabilidad identificada será documentada incluyendo:

- Descripción.
- Ubicación o funcionalidad afectada.
- Condiciones necesarias para reproducirla.
- Evidencia obtenida.
- Impacto potencial.
- Nivel de riesgo.
- Recomendaciones de mitigación.
- Prioridad de atención.

6. Fases del pentest

● Reconocimiento

Se recopilará información sobre la aplicación web autorizada y se identificará su superficie de ataque, funcionalidades, mecanismos de autenticación, tipos de usuarios y posibles puntos de entrada.

● Análisis de vulnerabilidades

Se realizarán pruebas sobre las funcionalidades identificadas para detectar posibles debilidades de seguridad y configuraciones que puedan representar un riesgo.

● Explotación

Se verificará la existencia de las vulnerabilidades encontradas mediante técnicas de explotación controladas, evitando afectar la disponibilidad de la plataforma o la información real de los clientes.

Se dará prioridad a comprobar si el incidente reportado corresponde a una vulnerabilidad de control de acceso que permita consultar información de otra cuenta.

- Post-explotación

Una vez confirmada una vulnerabilidad, se determinará hasta dónde podría llegar un atacante bajo condiciones controladas, sin realizar acciones destructivas ni acceder innecesariamente a información real.

El objetivo será establecer el alcance potencial de la vulnerabilidad y comprender sus consecuencias para Aurora Market.

- Informe

Se elaborará un informe técnico con las vulnerabilidades identificadas, evidencias, nivel de riesgo, impacto potencial y recomendaciones de mitigación.

7. Investigación

- Metodología elegida: OWASP

Se utilizará **OWASP** como referencia metodológica para la evaluación de la aplicación web.

OWASP proporciona recursos y metodologías orientadas a identificar y mitigar riesgos de seguridad en aplicaciones web. Su utilización permitirá estructurar las pruebas de manera ordenada y evaluar diferentes categorías de vulnerabilidades relacionadas con autenticación, autorización, validación de entradas, sesiones, configuraciones y manejo de información.

Para este proyecto, la metodología permitirá priorizar especialmente la evaluación de controles de autenticación y autorización, debido al reporte de un posible acceso de un usuario a información perteneciente a otra cuenta.

El objetivo no será únicamente identificar vulnerabilidades, sino comprender su impacto y proporcionar recomendaciones que permitan reducir el riesgo para Aurora Market.